

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check + Maven) · Generated 2026-06-11 · Source: `pom.xml`
Run branch: `fix/depSCAN-20260611-074147` · Source SHA: `72fe788e`

Summary — Before Fixes

Metric	Count
Total CVEs found	28
CRITICAL dependencies	3 (log4j-core, log4j-api, jackson-databind)
HIGH dependencies	4
MEDIUM dependencies	3
Outdated dependencies	8
License violations	1 (mysql-connector-java GPL-2.0)
Supply-chain alerts	2 (typosquat + HTTP mirror)

Remediation Status

Dependency	Was	Fixed to	CVEs Cleared	Status
org.apache.logging.log4j:log4j-core	2.14.1	2.17.1	CVE-2021-44228, CVE-2021-45046, CVE-2021-44832, CVE-2021-45105	✓ Fixed
org.apache.logging.log4j:log4j-api	2.14.1	2.17.1	CVE-2021-44228	✓ Fixed
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.14.0	CVE-2019-14379, CVE-2019-14540, CVE-2020-36518, CVE-2022-42003	✓ Fixed
mysql:mysql-connector-java	8.0.30	8.0.31	CVE-2022-21363	✓ Fixed (license MAJOR_REVIEW → issue opened)
commons-io:commons-io	2.4	2.14.0	CVE-2024-47554	✓ Fixed
org.apache.commons:commons-lang3	3.4	3.20.0	CVE-2025-48924	✓ Fixed
com.fastxml.jackson.core:jackson-databind	2.9.8	REMOVED	n/a — typosquat	✓ Removed
http://insecure-mirror.example.net/maven2	present	REMOVED	n/a — supply-chain	✓ Removed
com.google.guava:guava	24.1.1-jre	unchanged	CVE-2023-2976, CVE-2020-8908	⚠ MAJOR_REVIEW — issue opened

CVEs Cleared in This Run

CVE	Dependency	CVSS	Severity
CVE-2021-44228 (Log4Shell)	log4j-core / log4j-api	10.0	CRITICAL

CVE-2021-45046	log4j-core	9.0	CRITICAL
CVE-2019-14379	jackson-databind	9.8	CRITICAL
CVE-2019-14540	jackson-databind	9.8	CRITICAL
CVE-2020-36518	jackson-databind	7.5	HIGH
CVE-2022-42003	jackson-databind	7.5	HIGH
CVE-2022-21363	mysql-connector-java	6.6	MEDIUM
CVE-2024-47554	commons-io	4.3	MEDIUM
CVE-2025-48924	commons-lang3	5.3	MEDIUM
CVE-2021-44832	log4j-core	6.6	MEDIUM
CVE-2021-45105	log4j-core	5.9	MEDIUM

Remaining CVEs (human follow-up required)

CVE	Dependency	CVSS	Severity	Reason not auto-fixed
CVE-2023-2976	guava:24.1.1-jre	5.5	MEDIUM	Major version jump (24 → 32) — MAJOR_REVIEW
CVE-2020-8908	guava:24.1.1-jre	3.3	LOW	Same — MAJOR_REVIEW

Supply-chain alerts — Resolved

-  **Typosquat removed.** `com.fastxml.jackson.core:jackson-databind:2.9.8` removed from pom.xml.
-  **Untrusted repository removed.** `http://insecure-mirror.example.net/maven2` removed from pom.xml.

License violation — Human follow-up

 **MAJOR_REVIEW: mysql:mysql-connector-java** — GPL-2.0-with-FOSS-exception licence is incompatible with a permissive-only project policy. CVE patched (8.0.30 → 8.0.31) but replacement with a permissive-licensed driver (e.g. `com.mysql:mysql-connector-j`) requires human evaluation. Tracking issue opened.